

INFORME DE INCIDENTE DE SEGURIDAD — ORION FINANCIAL GROUP

- **Rol Simulado:** SOC Analyst L1
- **Área:** Security Operations / Incident Response
- **Caso de Estudio:** Proyecto 08B — Gestión, Escalamiento y Comunicación de Incidentes

Resumen Ejecutivo

El presente documento detalla el análisis, triage, contención y escalamiento de una alerta de seguridad generada por el SIEM en Orion Financial Group. La alerta indicó múltiples intentos fallidos de autenticación seguidos de un inicio de sesión exitoso en la cuenta de un usuario del área Comercial (cfernandez), con posterior acceso a recursos en la nube corporativa. Tras la validación de la evidencia, la correlación de eventos y la consulta con el usuario, se determinó la existencia de indicadores consistentes con un posible compromiso de cuenta, procediendo al escalamiento formal a SOC L2 e Incident Response siguiendo los playbooks establecidos.

Información Inicial de la Alerta

- **Fecha y Hora de Alerta:** Martes a las 10:12.
- **Cuenta Afectada:** cfernandez (Área Comercial).
- **Alerta del SIEM:** *"Multiple failed authentication attempts followed by successful login"*.
- **Dirección IP Origen:** 185.220.101.44.

Cronología de Eventos Iniciales (Timeline)

- **09:54 – 09:58:** 5 intentos fallidos de autenticación (FAILED) desde la IP 185.220.101.44.
- **09:59:** Autenticación exitosa (SUCCESS) desde la misma IP.
- **10:03:** Acceso al almacenamiento corporativo en la nube.
- **10:06:** Descarga del archivo clientes_Q3.xlsx (información comercial de clientes).
- **10:08:** Descarga del archivo contratos_clientes.zip (documentación interna).
- **10:10:** Intento de acceso al recurso compartido Finance-Shared (perteneciente al área de Finanzas).
- **10:12:** Disparo de la alerta en el SIEM.

Triage e Investigación de Evidencia

Siguiendo un flujo de trabajo estructurado, se diferenciaron los hechos demostrables de los elementos desconocidos para evitar falsas conclusiones:

- **Hechos Demostrables:** Se registraron 5 fallos de autenticación seguidos de un inicio de sesión exitoso desde la misma IP, posterior acceso al almacenamiento en la nube, dos descargas de archivos y un intento de acceso a recursos de Finanzas.
- **Contexto Adicional Investigado:**

- La IP 185.220.101.44 no registra asociaciones previas con el usuario cfernandez en los últimos 30 días.
- El dispositivo de origen no coincide con el endpoint corporativo habitual del usuario.
- El registro de identidad muestra que la autenticación no empleó Autenticación Multifactor (MFA), ya que el servicio específico aún no lo tenía aplicado.
- El usuario cfernandez fue consultado y confirmó no haber realizado dicha autenticación ni las descargas.
- El usuario posee permisos legítimos para acceder a los dos archivos descargados (clientes_Q3.xlsx y contratos_clientes.zip), pero no pertenece a Finanzas ni cuenta con autorización para acceder a Finance-Shared, siendo dicho intento rechazado.
- No se detectó evidencia de malware en el endpoint corporativo del usuario ni confirmación de exfiltración de datos hacia el exterior al momento del análisis.

Determinación del Incidente

La correlación de los eventos —IP no habitual, dispositivo desconocido, ausencia de MFA, negativa de actividad por parte del usuario, descargas de archivos y un intento posterior de acceso a recursos no autorizados— presenta múltiples indicadores consistentes con un **posible compromiso de cuenta** (*Account Compromise*).

Acciones de Respuesta y Contención

- **Contención Operativa:** Se procedió a la contención temporal de la cuenta afectada (cfernandez), revocando sesiones activas y aplicando medidas preventivas según los procedimientos internos para limitar el daño.
- **Preservación de Evidencia:** Se resguardaron los registros de autenticación, logs de nube, marcas de tiempo y metadatos de red sin realizar acciones destructivas sobre los endpoints.

Ticket de Escalamiento (L1 a L2 / Incident Response)

- **Cuenta Afectada:** cfernandez
- **Clasificación:** Posible compromiso de credenciales / acceso no autorizado
- **Resumen de Hallazgos:** Autenticación exitosa precedida de 5 fallos desde una IP externa no habitual y dispositivo desconocido sin MFA. El usuario desconoce la actividad. Se ejecutaron descargas de archivos permitidos y un intento bloqueado a Finance-Shared.
- **Aspectos Desconocidos:** Vector inicial de ataque (ej. phishing) y confirmación de exfiltración de datos.
- **Acciones Realizadas:** Validación con usuario, recopilación de logs, contención inicial de la cuenta y escalamiento para análisis forense profundo.

Comunicación del Incidente

- **Comunicación Técnica (SOC L2 / Equipo de Respuesta):** Se reportó el detalle granular de marcas de tiempo, direcciones IP, telemetría de identidad, comportamiento de descargas y estado de los controles de acceso y MFA.
- **Comunicación Ejecutiva / Stakeholders:** Se informó de manera resumida y sin sobrecarga técnica que se detectó actividad no reconocida en una cuenta corporativa con acceso a documentación, la cual fue contenida y se encuentra bajo investigación activa, sin confirmación de transferencia externa de información en esta etapa. Todo intercambio se realizó bajo estrictos criterios de clasificación de datos y canales seguros (*Need-to-Know*).

Lecciones Aprendidas y Recomendaciones de Mejora

- **Implementación de MFA:** Extender e instar obligatoriamente el uso de Autenticación Multifactor en todos los servicios de acceso corporativo y en la nube.
- **Monitoreo de Comportamiento:** Reforzar las reglas de detección para alertas de IPs y dispositivos no habituales combinados con descargas masivas de archivos.
- **Revisión de Playbooks:** Validar los tiempos de respuesta y optimizar los flujos de comunicación y coordinación interna.